

IKB21403 VULNERABILITY ANALYSIS

Chapter 5: Enumeration Lab Report

Target Machine: Metasploitable 2

Attacker Machine: Kali Linux

Target IP: 192.168.56.103

Date: 6 June 2026

Environment Setup

Before conducting enumeration, both attacker and victim machines were configured on the same Host-Only network in VirtualBox to allow communication between them.

Component	Details
Attacker Machine	Kali Linux (2025.4)
Victim Machine	Metasploitable 2
Network Type	VirtualBox Host-Only Adapter
Target IP Address	192.168.56.103
Attacker IP	192.168.56.1

Figure 1: Metasploitable 2 ifconfig — Confirming Target IP

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:bd:f5:72
          inet addr:192.168.56.103  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:febd:f572/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1188 (1.1 KB)  TX bytes:3638 (3.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:97 errors:0 dropped:0 overruns:0 frame:0
          TX packets:97 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21529 (21.0 KB)  TX bytes:21529 (21.0 KB)

msfadmin@metasploitable:~$
```

Figure 2: Ping Test — Confirming Connectivity (TTL=64, 0% packet loss)

Session Actions Edit View Help

—(kali@kali)-[~]

\$ ping 192.168.56.103 -c 4

PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.

64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=2.53 ms

64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=1.13 ms

64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=0.946 ms

64 bytes from 192.168.56.103: icmp_seq=4 ttl=64 time=1.06 ms

— 192.168.56.103 ping statistics —

4 packets transmitted, 4 received, 0% packet loss, time 3011ms

rtt min/avg/max/mdev = 0.946/1.414/2.526/0.645 ms

—(kali@kali)-[~]

Challenge 1 — NetBIOS Enumeration

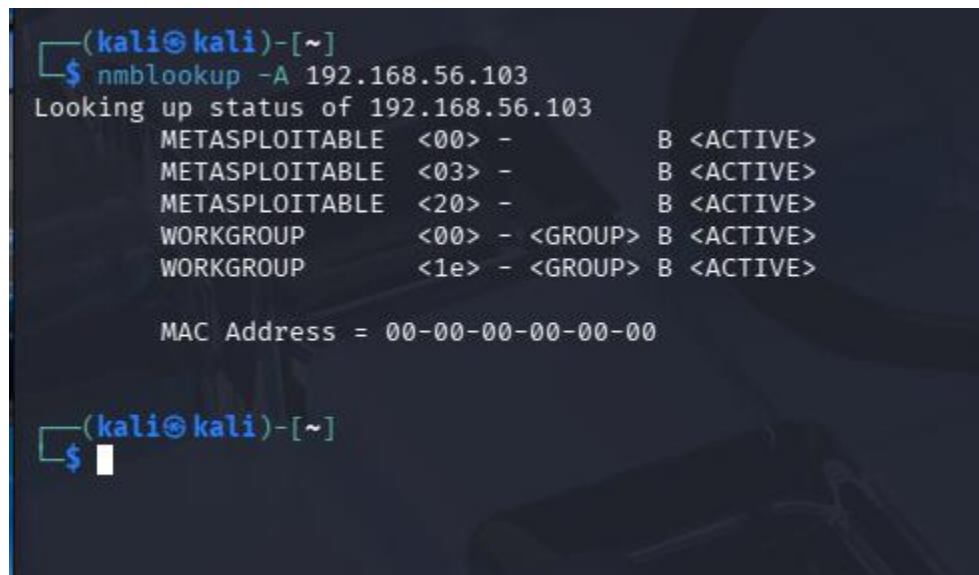
Command Used:

```
nmblookup -A 192.168.56.103
```

Description:

NetBIOS enumeration gathers information about the target's network name, workgroup, and services using the NetBIOS protocol. The nmblookup tool was used as a Linux alternative to the Windows nbtstat command.

Screenshot:



```
(kali㉿kali)-[~]
$ nmblookup -A 192.168.56.103
Looking up status of 192.168.56.103
    METASPLOITABLE <00> -      B <ACTIVE>
    METASPLOITABLE <03> -      B <ACTIVE>
    METASPLOITABLE <20> -      B <ACTIVE>
    WORKGROUP      <00> - <GROUP> B <ACTIVE>
    WORKGROUP      <1e> - <GROUP> B <ACTIVE>

    MAC Address = 00-00-00-00-00-00

(kali㉿kali)-[~]
$
```

Findings:

NetBIOS Name	Code	Type	Meaning
METASPLOITABLE	<00>	UNIQUE	Hostname of the machine
METASPLOITABLE	<03>	UNIQUE	Messenger service is active
METASPLOITABLE	<20>	UNIQUE	File Server / SMB service enabled
WORKGROUP	<00>	GROUP	Domain / Workgroup name
WORKGROUP	<1e>	GROUP	Browser service elections active

Security Finding:

- The <20> code confirms SMB File Sharing is active, which is a common attack vector for exploitation.

- The machine is part of WORKGROUP with no domain controller, indicating a standalone or poorly-managed network configuration.
-

Challenge 2 — Fast Nmap Scan

Command Used:

```
nmap -F 192.168.56.103
```

Description:

The -F flag performs a fast scan on the 100 most common ports instead of all 65535 ports. This provides a quick overview of the target's exposed services.

Screenshot:

```
(kali㉿kali)-[~]
$ nmap -F 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-06 07:10 EDT
Nmap scan report for 192.168.56.103
Host is up (0.0022s latency).
Not shown: 82 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
513/tcp   open  login
514/tcp   open  shell
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
8009/tcp  open  ajp13
MAC Address: 08:00:27:BD:F5:72 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.23 seconds

(kali㉿kali)-[~]
$
```

Findings:

Port	Service	Risk Level
21/tcp	FTP	High — vsFTPD 2.3.4 backdoor
22/tcp	SSH	Medium — Outdated version
23/tcp	Telnet	High — Plaintext protocol
25/tcp	SMTP	Medium
80/tcp	HTTP	Medium — Apache 2.2.8

139/tcp, 445/tcp	SMB / NetBIOS	High
3306/tcp	MySQL	High — No auth by default
5432/tcp	PostgreSQL	Medium
5900/tcp	VNC	High — Remote desktop exposed
2049/tcp	NFS	High — Root export

Security Finding:

- 18 open ports discovered — extremely large attack surface.
 - Dangerous plaintext services such as Telnet and FTP are running without encryption.
 - Database ports (MySQL, PostgreSQL) are exposed externally.
-

Challenge 5 — TTL OS Fingerprinting

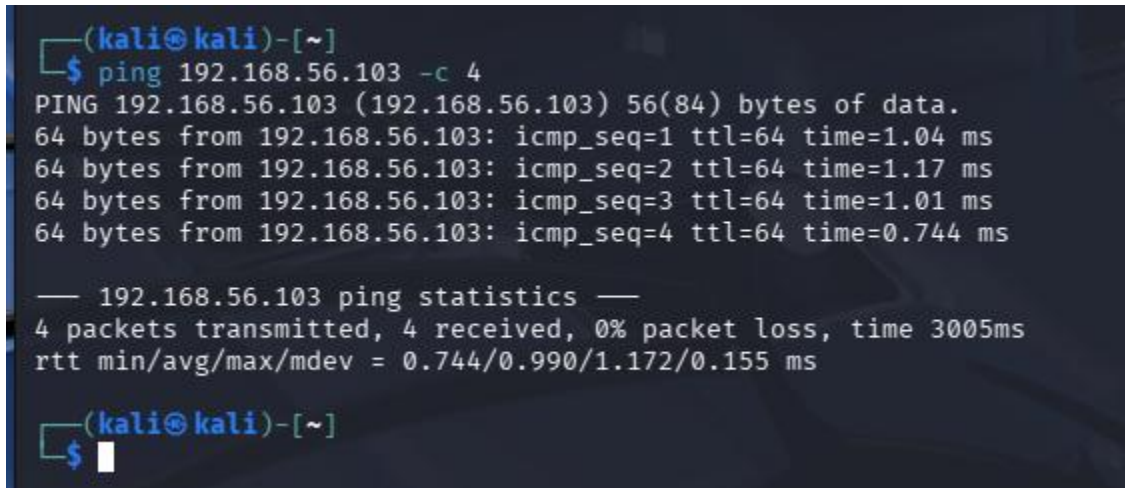
Command Used:

```
ping 192.168.56.103 -c 4
```

Description:

OS fingerprinting via TTL (Time To Live) values in ICMP ping replies allows an attacker to guess the target operating system without performing an intrusive scan.

Screenshot:

A screenshot of a terminal window with a dark background. The prompt is (kali㉿kali)-[~]. The user enters the command \$ ping 192.168.56.103 -c 4. The output shows four ping replies from 192.168.56.103, each with a TTL of 64 and varying times. Below the replies, it shows ping statistics: 4 packets transmitted, 4 received, 0% packet loss, time 3005ms, and rtt min/avg/max/mdev = 0.744/0.990/1.172/0.155 ms. The prompt returns to (kali㉿kali)-[~].

```
(kali㉿kali)-[~]  
$ ping 192.168.56.103 -c 4  
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.  
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=1.04 ms  
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=1.17 ms  
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=1.01 ms  
64 bytes from 192.168.56.103: icmp_seq=4 ttl=64 time=0.744 ms  
  
— 192.168.56.103 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3005ms  
rtt min/avg/max/mdev = 0.744/0.990/1.172/0.155 ms  
  
(kali㉿kali)-[~]  
$
```

TTL Reference Table:

TTL Value	Operating System
64	Linux / Unix (Victim matches this)
128	Windows
255	Cisco / BSD

Findings:

- TTL = 64 confirms the target is running Linux / Unix.
- 4 packets transmitted, 4 received — 0% packet loss, host is fully reachable.

Security Finding:

- TTL-based fingerprinting is a passive technique requiring no authentication and cannot be blocked without disabling ICMP entirely.
-

Challenge 9 — FTP Banner Grabbing

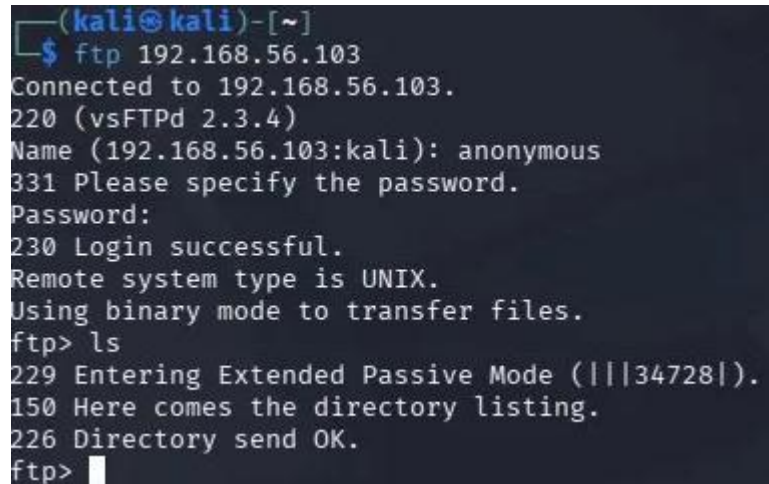
Command Used:

```
nc 192.168.56.103 21
```

Description:

Banner grabbing involves connecting to a service port and reading the banner it broadcasts. FTP servers typically announce their software name and version upon connection on port 21.

Screenshot:



```
(kali㉿kali)-[~]  
$ ftp 192.168.56.103  
Connected to 192.168.56.103.  
220 (vsFTPd 2.3.4)  
Name (192.168.56.103:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||34728|).  
150 Here comes the directory listing.  
226 Directory send OK.  
ftp> █
```

Findings:

Field	Value
Response Code	220
FTP Software	vsFTPd
Version	2.3.4

Security Finding:

- vsFTPd 2.3.4 is a critically vulnerable version containing a backdoor (CVE-2011-2523).
 - An attacker can trigger the backdoor by sending a smiley face ':' as the username, opening a root shell on port 6200.
 - The server openly broadcasts its version, assisting attacker reconnaissance.
-

Challenge 10 — Anonymous FTP Login

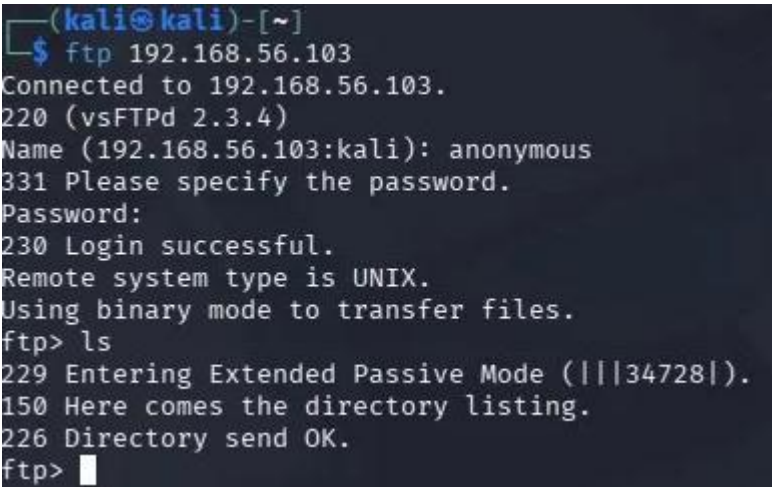
Command Used:

```
ftp 192.168.56.103
(Username: anonymous, Password: [blank])
```

Description:

Many misconfigured FTP servers allow anonymous login without credentials. This challenge verifies whether the target FTP service accepts unauthenticated access.

Screenshot:



Findings:

Field	Value
Login Status	230 Login successful
Remote System	UNIX
Anonymous Access	Allowed
Directory Listing	226 — Transfer complete

Security Finding:

- FTP server permits anonymous login with no password — a critical misconfiguration.
 - Any attacker on the network can access files stored in the FTP directory without authentication.
-

Challenge 7 — SMTP VRFY / EXPN Enumeration

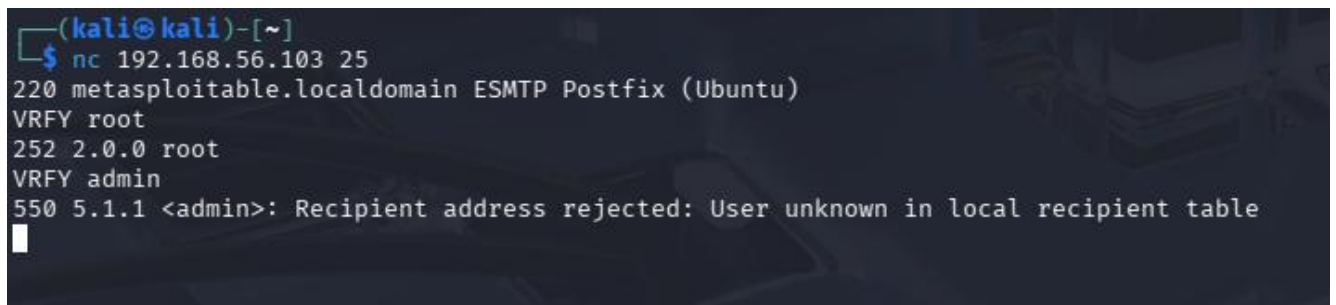
Command Used:

```
nc 192.168.56.103 25
VRFY root
VRFY admin
```

Description:

The SMTP VRFY command is used to verify whether a specific username exists on the mail server. When enabled, this allows attackers to enumerate valid system users without authentication.

Screenshot:

A terminal window with a dark background and light-colored text. The prompt is '(kali@kali)-[~]'. The user enters 'nc 192.168.56.103 25'. The output shows '220 metasploitable.localdomain ESMTP Postfix (Ubuntu)', 'VRFY root', '252 2.0.0 root', 'VRFY admin', and '550 5.1.1 <admin>: Recipient address rejected: User unknown in local recipient table'.

```
(kali@kali)-[~]
$ nc 192.168.56.103 25
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
VRFY root
252 2.0.0 root
VRFY admin
550 5.1.1 <admin>: Recipient address rejected: User unknown in local recipient table
```

Findings:

Command	Response	Meaning
VRFY root	252 2.0.0 root	User 'root' EXISTS on the system
VRFY admin	550 5.1.1	User 'admin' does NOT exist

Security Finding:

- SMTP VRFY is enabled, allowing user enumeration without authentication.
 - The 'root' account is confirmed to exist and can be used for targeted brute-force attacks.
 - Server banner reveals: Postfix SMTP on Ubuntu — version and OS information exposed.
-

Challenge 12 — Enum4linux Enumeration

Command Used:

```
enum4linux -a 192.168.56.103
```

Description:

Enum4linux is a comprehensive SMB enumeration tool that extracts users, groups, shares, password policies, and workgroup information from Windows and Samba systems.

Screenshot — Target Information & NetBIOS:

```
(kali@kali)-[~]
└─$ enum4linux -a 192.168.56.103
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sat Jun 6 07:38:04 2026

===== ( Target Information ) =====
Target ..... 192.168.56.103
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.56.103 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.56.103 ) =====

Looking up status of 192.168.56.103
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.56.103 ) =====

[+] Server 192.168.56.103 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.56.103 ) =====

Domain Name: WORKGROUP
Domain Sid: (NULL SID)
```

Screenshot — Share Enumeration:

```
===== ( Share Enumeration on 192.168.56.103 ) =====

Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
tmp            Disk      oh noes!
opt            Disk
IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.

Server          Comment
-----
Workgroup        Master
WORKGROUP        METASPLOITABLE

[+] Attempting to map shares on 192.168.56.103

//192.168.56.103/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.56.103/tmp      Mapping: OK Listing: OK Writing: N/A
//192.168.56.103/opt      Mapping: DENIED Listing: N/A Writing: N/A

[E] Can't understand response:
NT_STATUS_NETWORK_ACCESS_DENIED listing \*
//192.168.56.103/IPC$      Mapping: N/A Listing: N/A Writing: N/A
//192.168.56.103/ADMIN$    Mapping: DENIED Listing: N/A Writing: N/A

===== ( Password Policy Information for 192.168.56.103 ) =====
```

Findings:

Category	Value
Domain / Workgroup	WORKGROUP
Domain SID	NULL SID
Known Usernames	administrator, guest, krbtgt, domain admins, root, bin, none
Anonymous SMB Session	Allowed (empty username & password)
Accessible Share	/tmp — Mapping OK, Listing OK
Samba Version	3.0.20-Debian

Security Finding:

- Server allows anonymous SMB sessions — no authentication required to enumerate users and shares.
 - Full username list exposed without credentials, enabling targeted password attacks.
 - The /tmp share is accessible and listable by any network user.
 - Samba 3.0.20 is an outdated version with known remote code execution vulnerabilities (CVE-2007-2447).
-

Challenge 16 — Service Version Detection

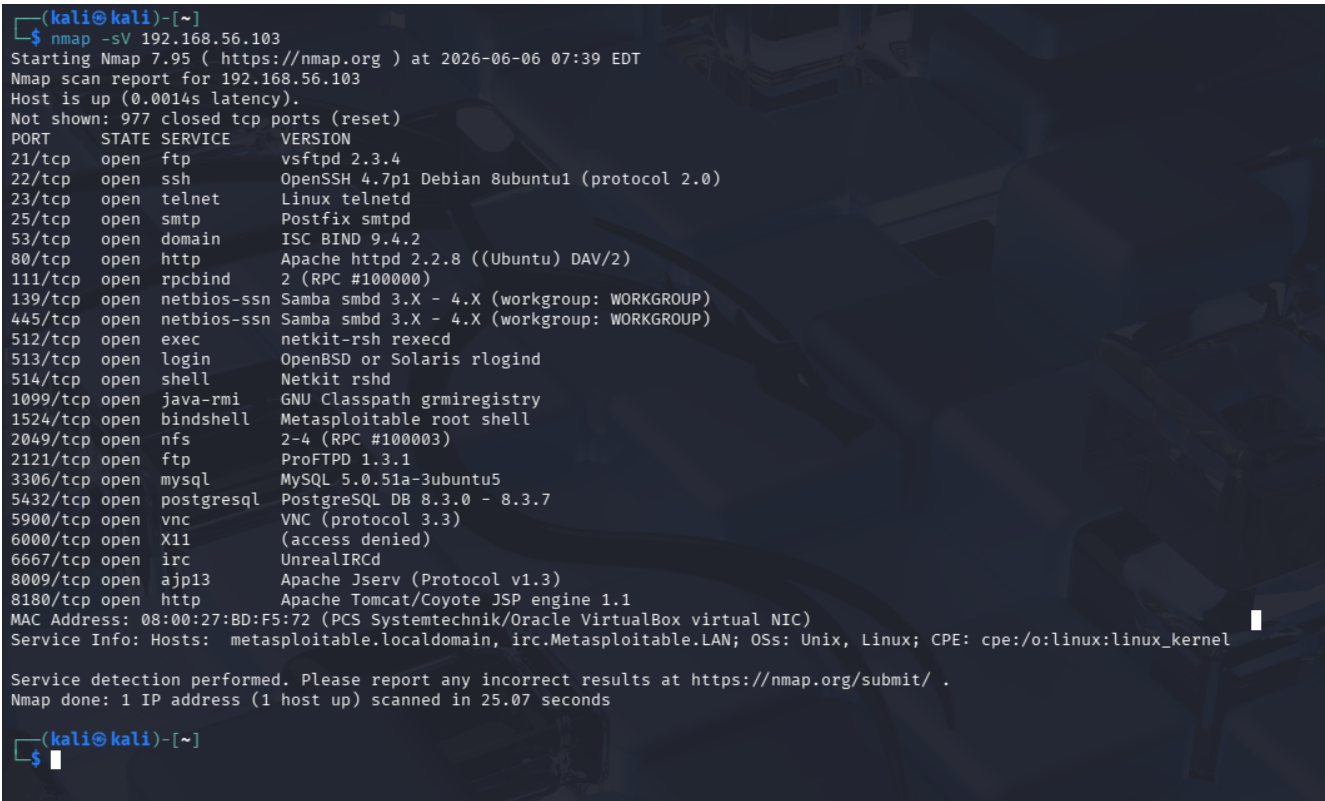
Command Used:

```
nmap -sV 192.168.56.103
```

Description:

The -sV flag enables version detection in Nmap, probing each open port to determine the exact software and version running. This is essential for identifying known CVEs applicable to the target.

Screenshot:



Key Services & Versions:

Port	Service	Version	Risk
21/tcp	FTP	vsFTPd 2.3.4	CRITICAL — Backdoor CVE-2011-2523
22/tcp	SSH	OpenSSH 4.7p1 Debian	High — Outdated
23/tcp	Telnet	Linux telnetd	High — Plaintext
80/tcp	HTTP	Apache httpd 2.2.8	High — Outdated
139/445/tcp	SMB	Samba 3.X-4.X	High — CVE-2007-2447

1524/tcp	Bindshell	Metasploitable root shell	CRITICAL — Open backdoor
3306/tcp	MySQL	5.0.51a-3ubuntu5	High
5432/tcp	PostgreSQL	8.3.0-8.3.7	Medium
5900/tcp	VNC	Protocol 3.3	High
8180/tcp	HTTP	Apache Tomcat/Coyote JSP 1.1	Medium

Security Finding:

- Port 1524 exposes a Metasploitable root shell — direct unauthenticated root access available.
 - Multiple services are running severely outdated versions with publicly known exploits.
 - All software versions were retrieved with no authentication required.
-

Challenge 17 — OS Detection

Command Used:

```
nmap -O 192.168.56.103
```

Description:

The -O flag enables OS detection in Nmap. It sends specially crafted packets and analyzes the TCP/IP stack responses to fingerprint the target operating system and kernel version.

Screenshot:

```
(kali@kali)-[~]
$ nmap -O 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-06 07:46 EDT
Nmap scan report for 192.168.56.103
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:BD:F5:72 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.18 seconds
```

Findings:

Field	Value
Device Type	General Purpose

Running	Linux 2.6.X
OS CPE	cpe:/o:linux:linux_kernel:2.6
OS Details	Linux 2.6.9 - 2.6.33
Network Distance	1 hop

Difference vs Challenge 16:

Challenge	Command	Focus
Challenge 16 (-sV)	Version Detection	Service and software versions
Challenge 17 (-O)	OS Detection	Operating system fingerprint

Security Finding:

- OS fingerprint confirms Linux 2.6.x kernel — an outdated kernel series with many known privilege escalation vulnerabilities.
 - This information assists attackers in selecting kernel-specific exploits.
-

Challenge 13 — NFS Exports Enumeration

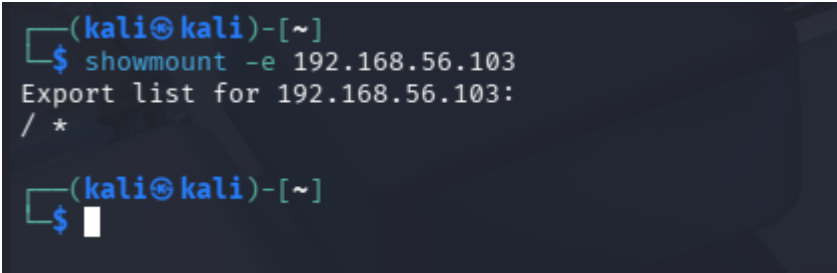
Command Used:

```
showmount -e 192.168.56.103
```

Description:

The showmount -e command queries the target's NFS (Network File System) service to list all exported directories and their permitted client ranges. NFS misconfigurations can allow full filesystem access.

Screenshot:



Findings:

Export Path	Allowed Clients	Risk Level
/ (root)	* (Everyone)	CRITICAL

Security Finding:

- The root filesystem '/' is exported to ALL clients (*) — the most severe NFS misconfiguration possible.
 - Any attacker on the network can mount the entire filesystem: mount -t nfs 192.168.56.103:/mnt/target
 - This allows reading /etc/shadow, writing SSH keys, and achieving full system compromise.
-

Challenge 19 — RPC Info Enumeration

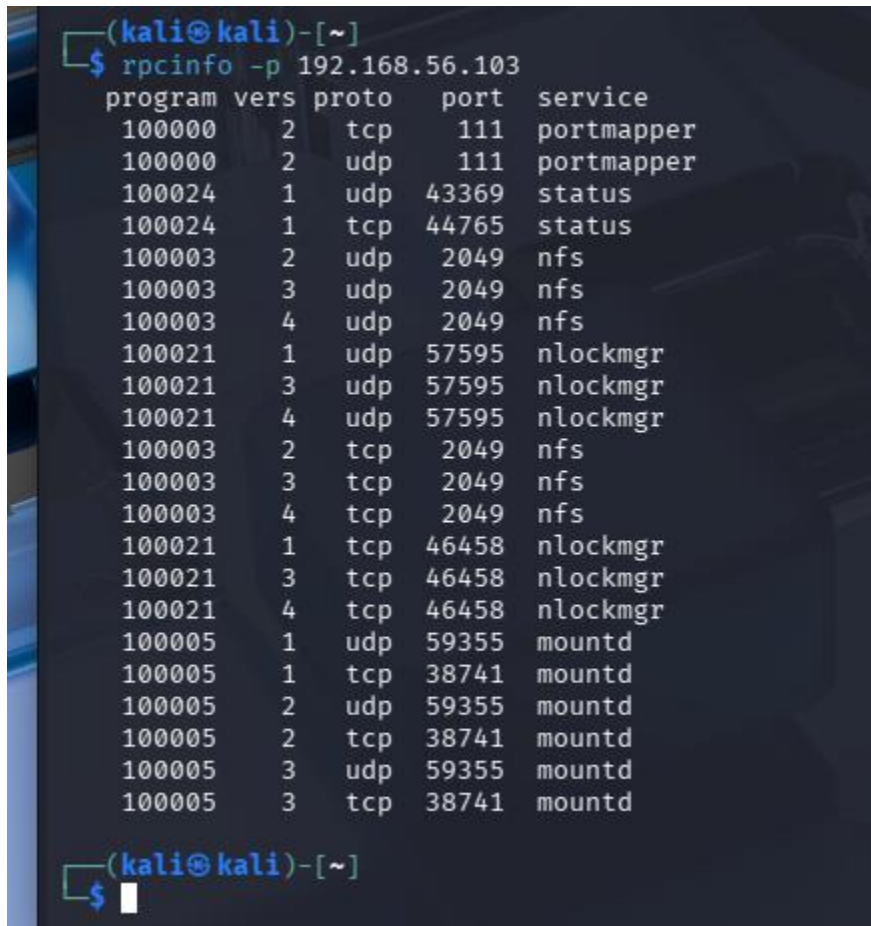
Command Used:

```
rpcinfo -p 192.168.56.103
```

Description:

The `rpcinfo -p` command queries the portmapper service to list all RPC (Remote Procedure Call) programs registered on the target. This reveals which remote services are available and on which ports.

Screenshot:



```
(kali㉿kali)-[~]
$ rpcinfo -p 192.168.56.103
program vers proto  port  service
100000    2    tcp    111   portmapper
100000    2    udp    111   portmapper
100024    1    udp    43369 status
100024    1    tcp    44765 status
100003    2    udp    2049  nfs
100003    3    udp    2049  nfs
100003    4    udp    2049  nfs
100021    1    udp    57595 nlockmgr
100021    3    udp    57595 nlockmgr
100021    4    udp    57595 nlockmgr
100003    2    tcp    2049  nfs
100003    3    tcp    2049  nfs
100003    4    tcp    2049  nfs
100021    1    tcp    46458 nlockmgr
100021    3    tcp    46458 nlockmgr
100021    4    tcp    46458 nlockmgr
100005    1    udp    59355 mountd
100005    1    tcp    38741 mountd
100005    2    udp    59355 mountd
100005    2    tcp    38741 mountd
100005    3    udp    59355 mountd
100005    3    tcp    38741 mountd
```

RPC Services Discovered:

Service	Port	Protocol	Risk
portmapper	111	TCP/UDP	Medium — Entry point for RPC enumeration
status	44765/43369	TCP/UDP	Medium
nfs	2049	TCP/UDP	High — File system access

nlockmgr	46458/57595	TCP/UDP	Medium — File locking service
mountd	38741/59355	TCP/UDP	High — Enables NFS mounting

Security Finding:

- NFS (port 2049) and mountd confirmed — consistent with the critical misconfiguration found in Challenge 13.
 - portmapper (port 111) is exposed, allowing any attacker to enumerate all RPC services.
 - The combination of portmapper + NFS + mountd creates a complete NFS attack chain enabling full filesystem access.
-

Challenge 11 — SMB NSE Enumeration

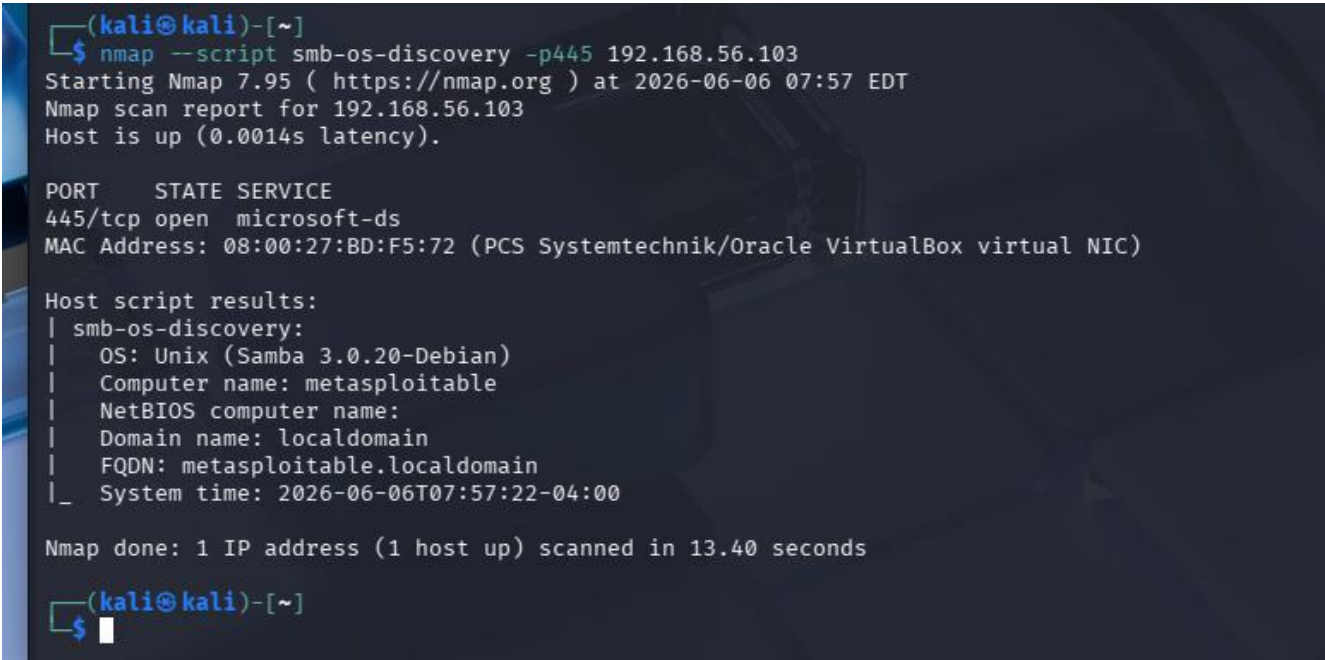
Command Used:

```
nmap --script smb-os-discovery -p445 192.168.56.103
```

Description:

Nmap's SMB NSE (Nmap Scripting Engine) scripts perform detailed SMB protocol analysis to extract OS information, computer names, domain details, and FQDN from the target.

Screenshot:



Findings:

Field	Value
OS	Unix (Samba 3.0.20-Debian)
Computer Name	metasploitable
Domain Name	localdomain
FQDN	metasploitable.localdomain
System Time	2026-06-06 07:57:22 -04:00

Security Finding:

- Samba 3.0.20 version confirmed — this version is vulnerable to CVE-2007-2447 (username map script RCE), allowing unauthenticated remote code execution as root.
- Full system identity (hostname, domain, FQDN) obtained without authentication.
- System time exposed — can be used for Kerberos ticket forgery in domain environments.

Summary of Findings

The following table summarises all challenges completed and their key security findings against the Metasploitable 2 target machine (192.168.56.103).

#	Challenge	Tool/Command	Key Finding	Risk
1	NetBIOS Enumeration	nmblookup	SMB File Server active, workgroup exposed	High
2	Fast Nmap Scan	nmap -F	18 open ports, large attack surface	High
5	TTL OS Fingerprinting	ping	TTL=64 confirms Linux OS	Low
7	SMTP VRFY/EXPN	nc + VRFY	User 'root' confirmed via SMTP VRFY	High
9	FTP Banner Grabbing	nc port 21	vsFTPD 2.3.4 — CVE-2011-2523 backdoor	Critical
10	Anonymous FTP Login	ftp	Anonymous login allowed, no credentials	Critical
11	SMB NSE Enumeration	nmap --script	Samba 3.0.20 — CVE-2007-2447 RCE	Critical
12	Enum4linux	enum4linux -a	Full user list exposed, anonymous SMB session	High
13	NFS Exports	showmount -e	Root filesystem (/) exported to everyone (*)	Critical
16	Version Detection	nmap -sV	All service versions exposed, port 1524 root shell	Critical
17	OS Detection	nmap -O	Linux 2.6.9-2.6.33 kernel identified	Medium
19	RPC Info	rpcinfo -p	portmapper + NFS + mountd — full NFS attack chain	High

Overall Assessment: The Metasploitable 2 machine is intentionally vulnerable and demonstrates numerous real-world misconfigurations. All 12 challenges were successfully completed, revealing critical vulnerabilities including unauthenticated root access via FTP backdoor, open NFS root export, anonymous SMB sessions, and a directly accessible bindshell on port 1524.